

QUESTION 4

A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

1. Introduction

Email is one of the most widely used communication methods in organizations. However, it is also one of the most common targets for cyberattacks. Spam emails, phishing messages, malicious attachments, and fraudulent links can enter an organization's network through email.

Basic email filtering systems generally depend on simple rules such as blocked keywords, blacklisted email addresses, known malicious domains, and attachment extensions. Although these techniques are useful, modern attackers can easily modify their messages to bypass such filters.

For example, instead of using obvious words such as "FREE MONEY" or "CLICK HERE", attackers may use carefully written messages that appear to come from banks, managers, HR departments, or other trusted organizations.

Therefore, an advanced spam detection system should analyze both:

- 1. Email headers**
- 2. Email content**

The proposed system can combine rule-based filtering with machine learning to identify suspicious messages more accurately.

2. A. Limitations of Existing Filtering Techniques

Traditional spam filtering has several weaknesses.

2.1 Keyword-Based Filtering

One of the simplest techniques is checking emails for suspicious keywords.

Examples include:

- Free
- Lottery
- Winner
- Urgent
- Password
- Click now
- Claim reward

The problem is that attackers can easily modify the wording.

For example:

Blocked message:

"Congratulations! You won a free prize."

An attacker could instead write:

"Your account has been selected for a special benefit."

The second message may bypass a simple keyword filter even though both messages have the same malicious purpose.

2.2 Blacklist-Based Filtering

A blacklist contains known malicious:

- IP addresses
- Email addresses
- Domains
- URLs

This technique is useful against previously identified attackers.

However, attackers frequently create:

- New domains
- Temporary email accounts
- Compromised legitimate accounts
- Random IP addresses

Therefore, a newly created malicious domain may not exist in the blacklist.

2.3 Static Rules

Traditional filters use fixed rules such as:

If attachment = .exe → block email.

This can produce both false positives and false negatives.

For example, legitimate administrators may need to send executable files in controlled environments. At the same time, attackers can rename malicious files or use compressed archives.

2.4 Difficulty Detecting Zero-Day Attacks

A traditional system generally depends on previously known attack patterns.

If a new phishing campaign appears, the system may not immediately recognize it.

This creates a security gap between:

New Attack → Detection → Rule Creation → Deployment

During this period, users may receive malicious emails.

2.5 False Positives

A legitimate email may accidentally contain suspicious words.

For example:

"Your bank security training presentation is attached."

A basic system may identify "bank" and "security" as suspicious depending on its rules.

If too many legitimate emails are blocked, users may lose confidence in the filtering system.

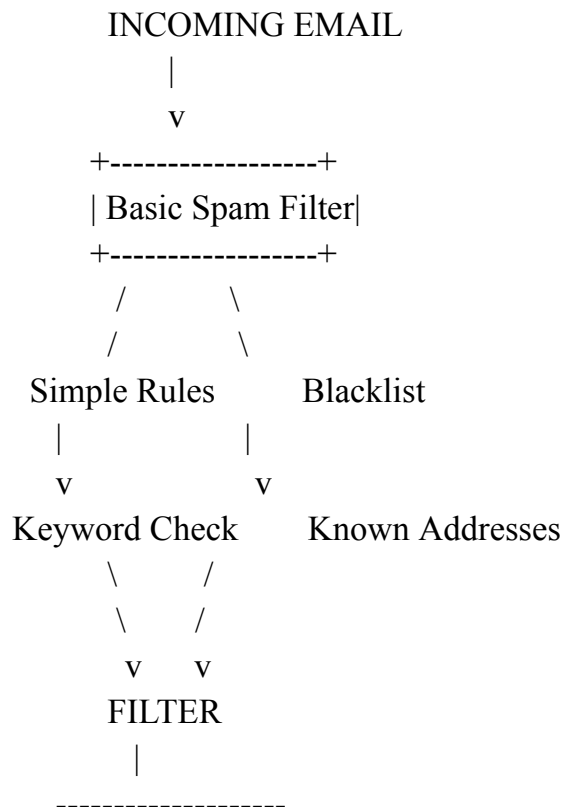
2.6 Evasion Techniques

Attackers use several methods to bypass basic filters:

- Misspelled words
- Images containing text
- URL shortening
- HTML obfuscation
- Unicode characters
- Encrypted attachments
- Compromised accounts
- Fake sender addresses

Therefore, content analysis alone is insufficient.

Figure 1 – Limitations of Traditional Spam Filtering



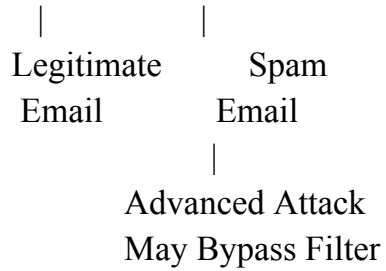


Figure 1: Limitations of traditional email filtering

3. B. Analysis of Email Headers for Spoofing Indicators

An email header contains technical information about the message. Header analysis is extremely important because attackers frequently manipulate the sender information.

Important header fields include:

- From
- To
- Reply-To
- Return-Path
- Received
- Message-ID
- Date
- Authentication-Results

3.1 From Header

The **From** field identifies the apparent sender.

For example:

From: security@company.com

This appears legitimate.

However, attackers can spoof the From address.

For example:

From: ceo@company.com

The actual message may have originated from an unrelated server.

Therefore, the From field should never be trusted by itself.

3.2 Reply-To Header

The Reply-To address specifies where replies should be sent.

An attacker could use:

From: manager@company.com

Reply-To: attacker@gmail.com

The user may believe that the message came from the manager. However, replying to it sends the message directly to the attacker's account.

This is an important phishing indicator.

3.3 Return-Path

The Return-Path indicates the address used for handling bounced messages.

Example:

From: accounts@company.com

Return-Path: randomuser@unknown-domain.com

A major mismatch between the apparent sender and return path can indicate spoofing.

3.4 Received Headers

The **Received** header shows the servers through which the email travelled.

Example:

Received: from mail.company.com

Received: from unknown-server.example.net

Received: from suspicious-domain.ru

By examining the chain of Received headers, security systems can identify unusual routing.

For example:

Sender

|

v

Unknown Server

|

v

Suspicious Server

|

v

Company Mail Server

|

v

Employee

An unexpected server or country can increase the risk score.

3.5 SPF Validation

Sender Policy Framework (SPF) checks whether the sending server is authorized to send email for a particular domain.

Example:

Authentication-Results:

spf=pass

or

spf=fail

An SPF failure is a strong spoofing indicator, although it should not automatically mean the message is malicious.

3.6 DKIM Validation

DomainKeys Identified Mail (DKIM) adds a digital signature to email.

The receiving mail server can verify that the message was signed by an authorized domain and that important parts of the message have not been modified.

Possible result:

dkim=pass

or

dkim=fail

A DKIM failure can increase the suspicion score.

3.7 DMARC Validation

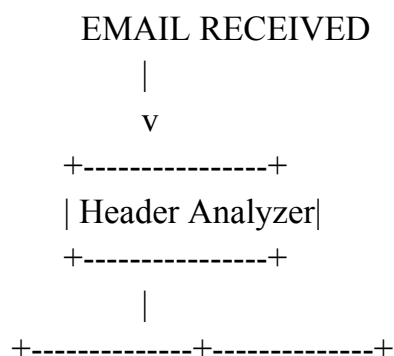
Domain-based Message Authentication, Reporting and Conformance (DMARC) combines domain alignment with SPF and DKIM.

Example:

dmARC=pass

A DMARC failure is an important indicator when determining whether a sender has been spoofed.

Figure 2 – Header-Based Spoofing Detection



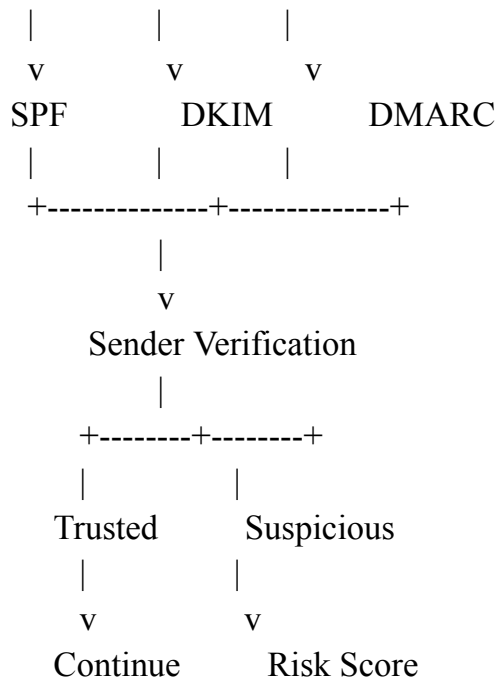


Figure 2: Email header authentication process

4. Content Analysis

Header analysis should be combined with content analysis.

Content analysis examines:

- Subject
 - Body text
 - URLs
 - Attachments
 - HTML structure
 - Language patterns
 - Urgency indicators
-

4.1 Subject Analysis

Phishing messages frequently use urgent subjects.

Examples:

- Urgent: Account Suspended
- Password Expiration Notice
- Immediate Action Required
- Payment Failed
- Verify Your Account

A machine learning model can identify such patterns instead of depending only on exact keywords.

4.2 URL Analysis

URLs should be examined for:

- Domain reputation
- HTTPS usage
- URL length
- IP address instead of domain
- Shortened URLs
- Suspicious domain names
- Look-alike domains

Example:

legitimate:

<https://company.com/login>

suspicious:

<https://company-security-login.example.net>

The second domain may look similar to a legitimate company website but belongs to another domain.

4.3 Attachment Analysis

Attachments should be examined based on:

- File type
- File size
- Hash value
- Malware reputation
- Macro presence
- Compression
- Encryption

Examples of high-risk attachments include:

invoice.exe
payment.scr
document.js
update.vbs

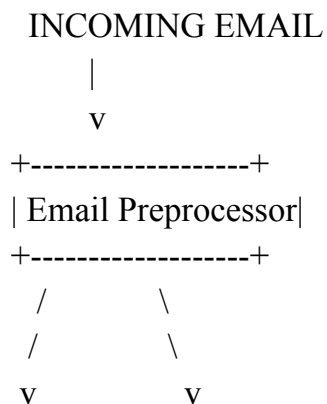
However, file extension alone should not determine whether an attachment is malicious.

5. C. Design of an Improved Detection Model

An advanced system can combine **rule-based detection and machine learning**.

The system can operate in multiple stages.

Proposed Architecture



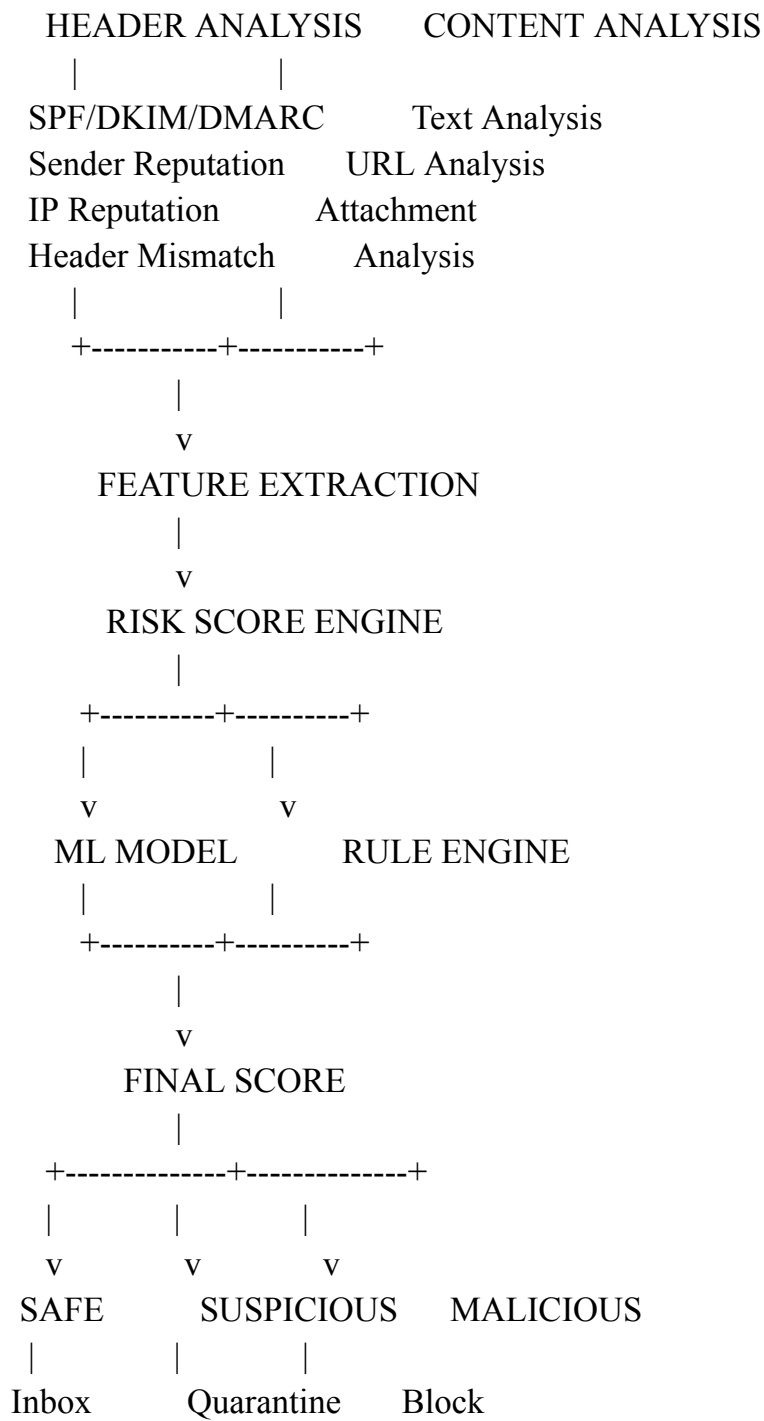


Figure 3: Proposed advanced spam detection architecture

5.1 Feature Extraction

The system extracts useful features from each email.

Header Features

- SPF result
- DKIM result
- DMARC result
- Sender domain
- Reply-To mismatch
- Return-Path mismatch
- Number of Received servers
- IP reputation
- Domain reputation

Content Features

- Subject characteristics
 - Word frequency
 - Urgency level
 - Number of links
 - URL reputation
 - HTML characteristics
 - Attachment type
 - Suspicious phrases
-

5.2 Rule-Based Detection

The rule engine can assign scores.

Example:

Indicator	Risk Score
SPF failure	+20
DKIM failure	+15

DMARC failure	+25
Reply-To mismatch	+20
Suspicious URL	+25
Malicious attachment	+40
Known bad IP	+40
Urgent language	+10

Example:

SPF failure	= 20
DMARC failure	= 25
Suspicious URL	= 25
Urgent language	= 10

Total Risk Score	= 80

If:

0–30 = Safe
 31–60 = Suspicious
 61–100 = High Risk

the above email would be classified as **High Risk**.

5.3 Machine Learning Model

A machine learning classifier can improve detection.

Possible algorithms include:

- Naive Bayes
- Logistic Regression
- Decision Tree

- Random Forest
- Support Vector Machine
- Gradient Boosting

For text-based spam classification, **Naive Bayes** and **Logistic Regression** are commonly suitable starting points.

The email text can be converted into numerical features using **TF-IDF**.

Example:

Email Text

|

v

Text Cleaning

|

v

Tokenization

|

v

TF-IDF

|

v

ML Classifier

|

v

Spam / Legitimate

5.4 Hybrid Detection

The best solution is a hybrid approach.

The rule engine handles obvious attacks, while machine learning detects unknown patterns.

For example:

Rule Score = 65%

ML Probability = 90%

Final Risk = High

This approach provides stronger detection than using only one technique.

6. D. Evaluation of Effectiveness

The performance of the system should be measured using standard classification metrics.

6.1 Accuracy

Accuracy represents the percentage of correctly classified emails.

$$\text{Accuracy} = \frac{TP + TN}{TP + TN + FP + FN}$$

Where:

- TP = True Positive
 - TN = True Negative
 - FP = False Positive
 - FN = False Negative
-

6.2 Precision

Precision measures how many emails classified as spam were actually spam.

$$\text{Precision} = \frac{TP}{TP + FP}$$

High precision means fewer legitimate emails are incorrectly marked as spam.

6.3 Recall

Recall measures how many actual spam emails were detected.

$$\text{Recall} = \frac{\text{TP}}{\text{TP} + \text{FN}}$$

A high recall is important because missing a phishing email can result in serious security incidents.

6.4 F1 Score

F1-score combines precision and recall.

$$\text{F1} = \frac{2 \times (\text{Precision} \times \text{Recall})}{\text{Precision} + \text{Recall}}$$

It is useful when the system needs to balance spam detection with legitimate email delivery.

7. False Positive Handling

False positives occur when legitimate emails are incorrectly classified as spam.

This is a major concern in enterprise environments.

A good system should not immediately delete every suspicious email.

Instead, it can use three levels:

Risk Level

+-----	Low Risk -----> Inbox
+-----	Medium Risk ---> Spam/Quarantine
+-----	High Risk -----> Block

Suspicious emails can be placed into quarantine for review.

Users can also report:

- "Not Spam"
- "Spam"
- "Phishing"

These feedback signals can be used to improve the model.

8. Continuous Model Improvement

The system should continuously learn from new attacks.

The process can be:

New Email

|

Detection

|

User Feedback

|

Security Team Review

|

New Training Data

|

Model Retraining

|

Improved Detection

This allows the system to adapt to new phishing techniques.

9. Conclusion

Basic email filtering techniques are no longer sufficient against modern phishing and spam attacks. Keyword filters, blacklists, and static rules can be bypassed through spoofing, new domains, obfuscation, and carefully written content.

An advanced system should analyze both email headers and message content. SPF, DKIM, and DMARC can help detect sender spoofing, while URL, attachment, subject, and text analysis can identify suspicious content.

A hybrid system combining rule-based detection with machine learning provides a stronger solution. Risk scoring, quarantine mechanisms, user feedback, and continuous model retraining can further improve security while reducing false positives.

Therefore, the proposed system provides a scalable and intelligent approach to protecting organizational email infrastructure.

QUESTION 5

During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

1. Introduction

S/MIME, or **Secure/Multipurpose Internet Mail Extensions**, is a security technology used to protect email communication.

It provides two important security services:

1. **Encryption**
2. **Digital signatures**

Encryption provides confidentiality, while digital signatures provide authentication and integrity.

S/MIME depends heavily on digital certificates and public-key cryptography. Therefore, improper certificate management can weaken the entire security system.

Possible problems include:

- Expired certificates
 - Revoked certificates
 - Incorrect certificate validation
 - Weak private-key protection
 - Untrusted certificate authorities
 - Incorrect trust chains
 - Poor certificate storage
 - Lack of certificate renewal procedures
-

2. A. Potential Certificate-Related Vulnerabilities

2.1 Expired Certificates

Digital certificates have a validity period.

Example:

Valid From: 01-01-2025

Valid To: 31-12-2025

After the expiration date, the certificate should no longer be trusted for normal use.

If an organization fails to monitor certificate expiration, users may experience failed email encryption or signature validation.

2.2 Revoked Certificates

A certificate may need to be revoked before expiration.

Reasons include:

- Private key compromise
- Employee leaving the organization
- Certificate issued incorrectly
- Loss of trust

- Security incident

Certificate revocation can be checked using mechanisms such as:

- CRL
 - OCSP
-

2.3 Compromised Private Key

The private key is extremely sensitive.

If an attacker obtains a user's private key, they may be able to:

- Impersonate the user
- Create fraudulent signatures
- Decrypt messages intended for the user

Therefore, private keys must be securely protected.

2.4 Weak Certificate Validation

An email client should not simply accept any certificate.

It should verify:

- Certificate validity
 - Issuer
 - Signature
 - Trust chain
 - Revocation status
 - Subject identity
 - Key usage
 - Algorithm strength
-

2.5 Untrusted Certificate Authority

A certificate is normally issued by a Certificate Authority (CA).

If the CA is not trusted by the organization, the certificate should not automatically be accepted.

A malicious or unauthorized CA could potentially issue fraudulent certificates.

2.6 Incorrect Certificate Storage

Storing private keys in insecure locations creates a major vulnerability.

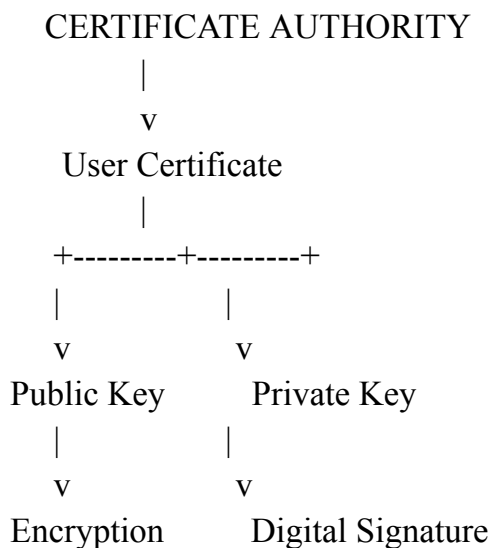
Examples of poor practices include:

C:\Users\Public\privatekey.pfx

or storing passwords alongside the certificate.

Private keys should be protected using operating system security mechanisms, hardware security modules, or secure key stores where appropriate.

Figure 4 – S/MIME Security Structure



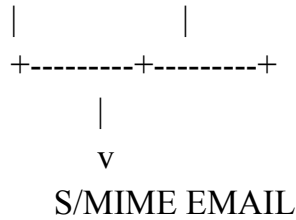
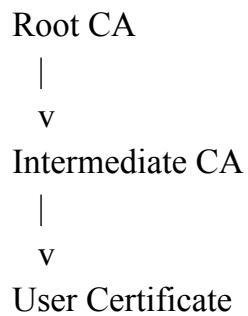


Figure 4: Basic S/MIME certificate structure

3. B. Trust Chain and Validation Process

Certificate validation involves checking whether the certificate can be trusted.

A typical certificate chain looks like:



The root CA is the trust anchor.

The intermediate CA provides a link between the root CA and the user's certificate.

3.1 Root Certificate

The root certificate belongs to a trusted Certificate Authority.

The organization must decide which root CAs are trusted.

3.2 Intermediate Certificate

The intermediate CA issues certificates on behalf of the root CA.

It helps separate the root CA from day-to-day certificate issuance.

3.3 End-Entity Certificate

This is the certificate assigned to the user.

Example:

User: employee@company.com

Certificate: User S/MIME Certificate

The email client validates the complete chain.

Figure 5 – Certificate Trust Chain

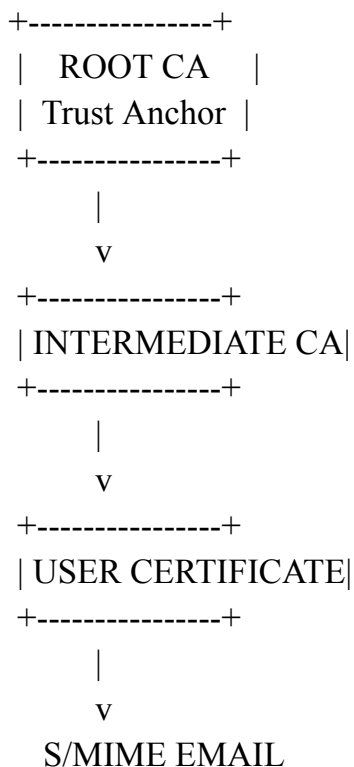


Figure 5: S/MIME certificate trust chain

4. Certificate Validation Process

When a user receives a digitally signed S/MIME email, the email client should perform several checks.

Step 1 – Check Certificate Validity

The system verifies:

Current Date $\geq$ Valid From

Current Date $\leq$ Valid To

If not, the certificate is invalid or expired.

Step 2 – Verify Certificate Signature

The certificate's digital signature should be verified using the issuing CA's public key.

Step 3 – Build the Trust Chain

The client identifies:

User Certificate



Intermediate CA



Root CA

Step 4 – Check Revocation

The system checks whether the certificate has been revoked.

Common methods include:

CRL – Certificate Revocation List

and

OCSP – Online Certificate Status Protocol

Step 5 – Verify Identity

The email identity should correspond with the certificate identity.

For example:

Email:

manager@company.com

Certificate:

manager@company.com

A mismatch should raise a warning.

Step 6 – Check Key Usage

The certificate must be appropriate for its intended purpose.

For example:

Digital Signature

Email Protection

Key Encipherment

A certificate should not be used outside its authorized purpose.

5. C. Secure Certificate Storage and Management

Certificate management should be treated as an organizational security process.

5.1 Protect Private Keys

Private keys should never be stored in ordinary folders where other users can access them.

Recommended storage options include:

- Operating system protected certificate stores
 - Hardware Security Modules
 - Smart cards
 - Secure tokens
 - Enterprise key management systems
-

5.2 Strong Password Protection

If certificates are exported into formats such as PFX/PKCS#12, the file should be protected with a strong password.

Bad example:

password123

Better approach:

Use a strong, unique credential and protect it through the organization's approved credential management system.

5.3 Access Control

Only authorized users should have access to private keys.

Example:

Employee

|
v
Authentication
|
v
Authorization
|
v
Private Key Access

This follows the principle of least privilege.

5.4 Certificate Inventory

Organizations should maintain a centralized certificate inventory.

The inventory should contain:

Information	Purpose
Certificate Owner	Identify user
Email Address	Identity
Issuer	Identify CA
Serial Number	Certificate identification
Issue Date	Certificate lifecycle
Expiry Date	Renewal
Status	Valid/Revoked
Key Type	Cryptographic information

5.5 Automatic Renewal

Manual renewal can result in expired certificates.

Therefore, organizations should implement automated monitoring.

Example:

Certificate Expiry

|

v

30 Days Remaining

|

v

Administrator Alert

|

v

Certificate Renewal

|

v

New Certificate

|

v

Deployment

5.6 Certificate Revocation

When a private key is compromised or an employee leaves the organization, the certificate should be revoked immediately.

The process should be:

Security Incident

|

v

Identify Certificate

|

v

Revoke Certificate

|

v

Update CRL / OCSP

|

v

Notify Systems

6. D. User Awareness and System Configuration

Technical controls alone are not enough. Users must understand S/MIME certificate warnings.

6.1 User Training

Employees should be trained to recognize:

- Expired certificate warnings
- Untrusted certificate warnings
- Invalid signature messages
- Certificate mismatch warnings
- Unexpected encryption failures

Users should not simply click "**Trust Certificate**" without understanding the warning.

6.2 Certificate Warning Example

A mail client might display:

WARNING

The sender's certificate cannot be trusted.

Possible reasons:

- Certificate expired
- Certificate revoked
- Unknown Certificate Authority
- Certificate chain invalid

[View Certificate] [Cancel]

Users should report such warnings to IT/security teams.

6.3 Secure Email Client Configuration

The organization should configure email clients to:

- Validate certificates automatically
 - Check certificate expiration
 - Check revocation status
 - Validate trust chains
 - Warn users about invalid certificates
 - Prevent unauthorized certificate installation
-

6.4 Strong Cryptographic Algorithms

Organizations should avoid obsolete cryptographic algorithms and weak key sizes.

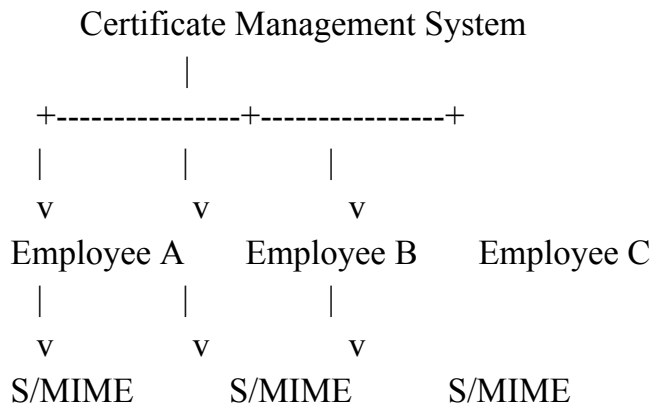
Security policies should specify approved:

- Public-key algorithms
- Key sizes
- Hash algorithms
- Signature algorithms
- Encryption algorithms

Cryptographic standards should be reviewed periodically because algorithms considered secure today may become weak in the future.

6.5 Centralized Certificate Management

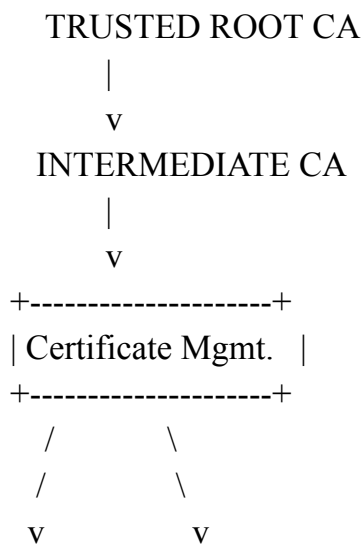
Large organizations should use centralized certificate management.



The centralized system can manage:

- Certificate issuance
 - Renewal
 - Revocation
 - Monitoring
 - Key protection
 - Auditing
-

7. Recommended Secure S/MIME Architecture



2. Check certificate expiration.
3. Check revocation status.
4. Verify the certificate identity.
5. Verify key usage.
6. Reject invalid or untrusted certificates.

User Security

1. Train users about certificate warnings.
 2. Explain phishing and certificate spoofing.
 3. Encourage users to report suspicious messages.
 4. Prevent users from installing unknown certificates.
 5. Provide clear instructions for handling certificate errors.
-

9. Evaluation of S/MIME Security

A secure S/MIME implementation should be evaluated using several factors.

Security Area	Expected Result
Certificate validity	Valid
Certificate expiration	Monitored
Revocation checking	Enabled
Trust chain	Complete
Private-key protection	Strong
CA trust	Controlled
User awareness	High
Certificate renewal	Automated

Certificate inventory Maintained

Email client Enabled
validation

Regular security audits should verify that these controls are functioning correctly.

10. Example of a Certificate Security Failure

Consider an employee named Arun.

The employee has an S/MIME certificate:

Email: arun@company.com

Certificate Status: Expired

The organization has not configured certificate expiry monitoring.

Another employee receives a signed email from Arun.

The email client fails to properly validate the certificate and accepts the signature without clearly warning the user.

This creates a security risk because users may assume that the message is trustworthy.

A properly configured system should instead perform:

Receive Email

|

v

Check Certificate

|

v

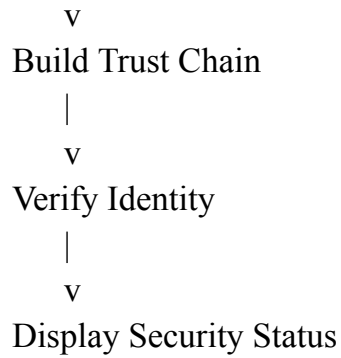
Check Expiration

|

v

Check Revocation

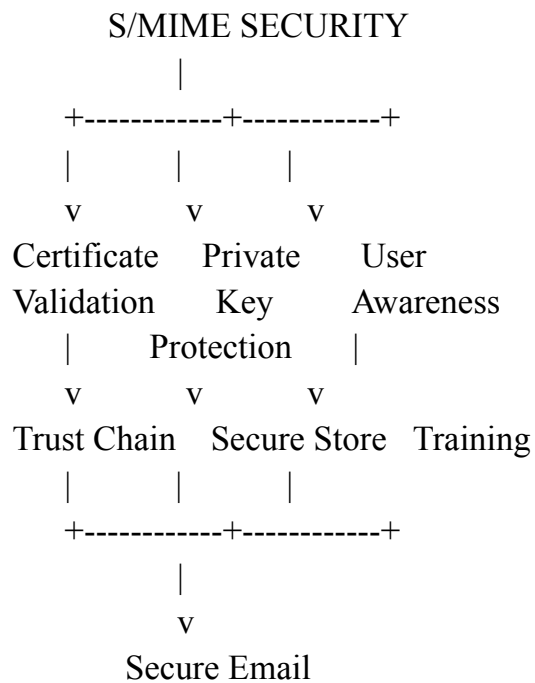
|



If validation fails, the user should receive a clear warning.

11. Overall Security Improvement

The organization can improve S/MIME security using a layered approach.



This layered approach reduces dependence on a single security mechanism.

12. Conclusion

S/MIME provides strong security for email communication, but its effectiveness depends on proper certificate management. Improper handling of certificates can result in expired certificates, revoked certificates being accepted, compromised private keys, invalid trust chains, and unauthorized certificate authorities.

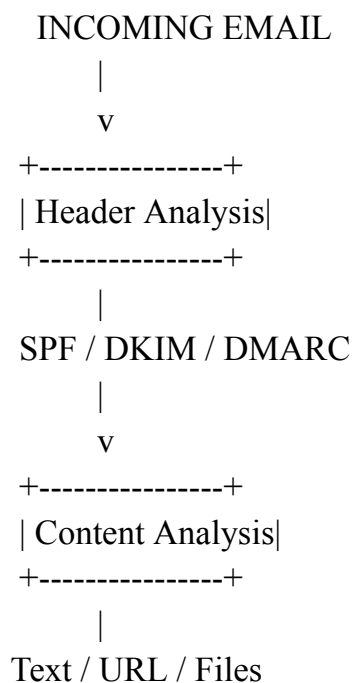
A secure S/MIME implementation must validate the complete certificate chain, verify certificate identity, check expiration and revocation status, and ensure that private keys are securely stored.

Organizations should also maintain a centralized certificate inventory, automate renewal, immediately revoke compromised certificates, and configure email clients to perform strict certificate validation.

Finally, users must be trained to understand certificate warnings and report suspicious messages. Combining strong technical controls with proper certificate lifecycle management and user awareness provides a reliable security framework for protecting S/MIME-based email communication.

Combined Key Diagrams for the Assessment

Diagram 1 – Advanced Spam Detection



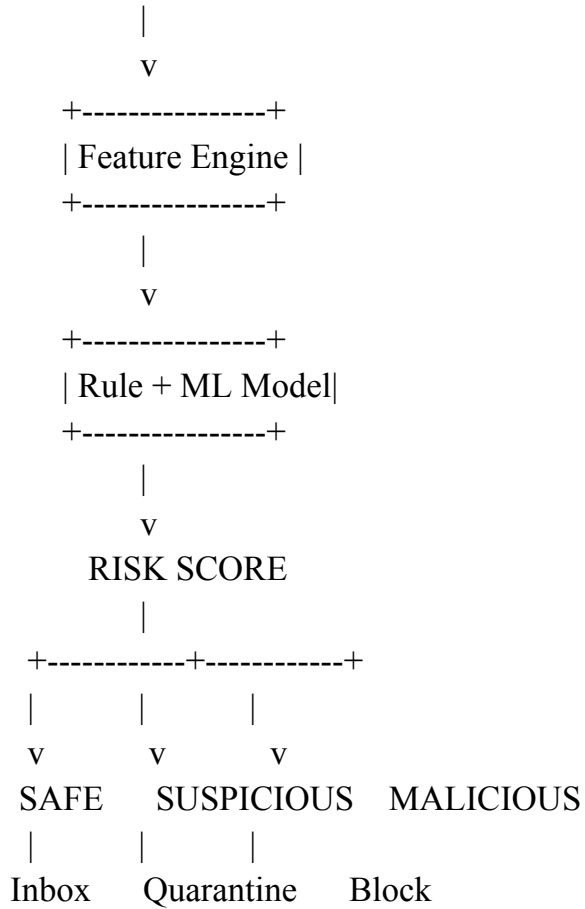
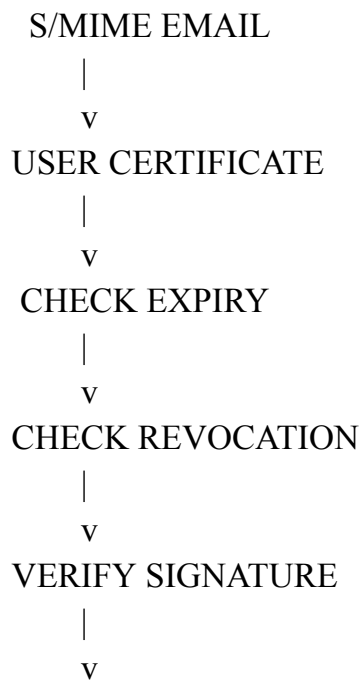
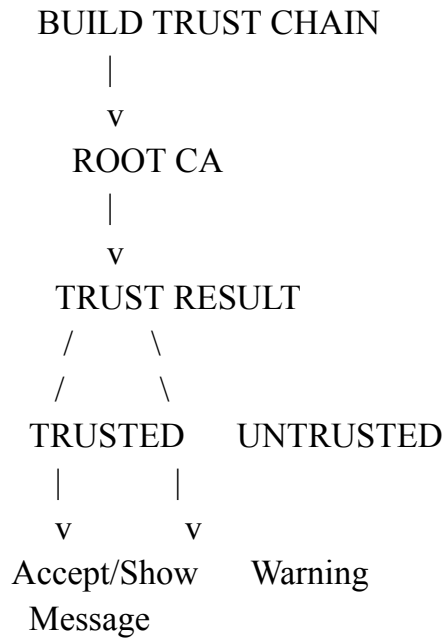


Diagram 2 – S/MIME Certificate Validation





Final Summary

Question 4 focuses on improving spam and phishing detection through **header analysis, SPF, DKIM, DMARC, content analysis, rule-based scoring, machine learning, and false-positive handling**.

Question 5 focuses on protecting S/MIME communication through **certificate validation, trust-chain verification, revocation checking, secure private-key storage, certificate lifecycle management, user awareness, and secure email-client configuration**.

Together, these approaches provide a layered email security architecture that can detect malicious messages while maintaining the confidentiality, integrity, authentication, and trust required for secure organizational communication.